Patch Management

INSTRUCTIONS:
Please respond to each question by placing an "X" in the "Yes", "No" or "N/A" column or by providing the information requested. Use the "Tab" key to move between items. Use the "Additional information" field for explanatory comments, if necessary. If an item does not have an "Additional information" field, and you need to explain your answer, use the space at the end of the questionnaire and reference the item being explained, e.g. RE: Item 1.2-This is the explanation.

Questionnaire completed by: _____

Contact number for follow-up questions: _____

Date Completed: _____

1. Policies and Procedures

Number	Question	Yes	No	N/A
1.1	Is there a written patch management policy for the organization? *If you answered "No" to this question, skip to Section 2, Patch Impact Assessments* Additional information: _____	☐	☐	☐
1.2	Has the patch management policy been approved by the Board of Directors or by management? Additional information: _____	☐	☐	☐
1.3	Is the patch management policy reviewed on a regular basis and updated as the environment changes? Additional information: _____	☐	☐	☐
1.4	Are there different patch management policies, procedures or software used in different areas of your network? (for example: you have a different patch management policy or procedure or use different software in your branch offices or in the DMZ than you use on the LAN) Additional information: _____	☐	☐	☐
Please provide an electronic copy of your patch management policies and procedures when you return this questionnaire to the auditors.				

Number	Question	Yes	No	N/A
1.5	Do patch management policy and procedures include the following elements:			
1.5.1	Purpose	☐	☐	☐
1.5.2	Scope	☐	☐	☐
1.5.3	Periodic revision requirement	☐	☐	☐
1.5.4	Definitions (If required)	☐	☐	☐
1.5.5	Enforcement provisions	☐	☐	☐
1.5.6	Revision history	☐	☐	☐
1.5.7	Patch deployment for operating systems	☐	☐	☐
1.5.8	Patch deployment for installed applications	☐	☐	☐
1.5.9	Patch testing procedures	☐	☐	☐
1.5.10	Backout procedures for incompatible patches	☐	☐	☐
1.5.11	Individuals authorized to download and install patches	☐	☐	☐
1.5.12	Patch procedures for mobile devices	☐	☐	☐
1.5.13	Patch impact assessments	☐	☐	☐
1.5.14	Patch change control process	☐	☐	☐

2. Patch Impact Assessments

Number	Question	Yes	No	N/A
2.1	Are formal patch impact assessments conducted? *If you answered "No" to this question, skip to Section 3, Patch Management Change Control* Additional information:	☐	☐	☐
2.2	Are patch impact assessments conducted that:			
2.2.1	Assesses whether the patch will correct a problem with the services or features of an operating system/application that the credit union is using (Technical evaluation assessment) Additional information:	☐	☐	☐
2.2.2	Determines if applying or not applying the patch will impact business processes and an appropriate time to apply the patch (after hours, weekends, etc) (Business impact assessment) Additional information:	☐	☐	☐

Number	Question	Yes	No	N/A
2.2.3	Identifies security implications not identified during the technical evaluation assessment (Security evaluation assessment) Additional information:	☐	☐	☐
2.2.4	Are patches applied in a test environment and their effect assessed before being applied in the production environment? Additional information:	☐	☐	☐

3. Patch Change Control

Number	Question	Yes	No	N/A
3.1	Is there a formal change control process for patch management? *If you answered "No" to this question, skip to Section 4, Patch Management Software* Additional information:	☐	☐	☐
3.2	Is there an emergency change control process to be used only in specific, authorized circumstances when the normal change control process would result in too great a delay in applying a patch? Additional information:	☐	☐	☐
3.3	Is there a process to "back out" of a patch application that proves to be incompatible or has unexpected consequences? Additional information:	☐	☐	☐
3.4	When patches are applied to a specific system, is there a record of that patch being applied and who applied it? Additional information:	☐	☐	☐

4. Patch Management Software

Number	Question	Yes	No	N/A
4.1	Is patch management software used by the organization? *If you answered "No" to this question, skip to Section 6 ,Patch Maintenance Management.*	☐	☐	☐
4.2	Does the patch management software generate failure alerts if a patch was not successfully applied? Additional information:	☐	☐	☐
4.3	Is a copy of the currently installed patch management software available on-site, not part of a tape backup? Additional information:	☐	☐	☐

Number	Question	Yes	No	N/A
4.4	Is a copy of the currently installed patch management software stored in a secure location off-site, for use during disaster recovery? Additional information:	☐	☐	☐
4.5	Are all copies of installed patch management software licensed for use? Additional information:	☐	☐	☐

5. Patch Management Software Configuration and Operation

Number	Question	Yes	No	N/A
5.1	Is the installation and update of patch management client software (if used) centrally managed? (patch management engine installation and updates are pushed from one or more servers to each client vice each client obtaining engine updates individually) Additional information:	☐	☐	☐
5.2	Is the patch update process centrally managed? (Updates are pushed from one or more servers to each client vice each client obtaining patch updates individually) Additional information:	☐	☐	☐
5.3	Is the patch management update process manually or automatically initiated? Additional information:	☐ Manually	☐ Automatically	
5.4	How often are patch files updated from the vendor to the central server?			
5.5	How often are patch files at the client updated from the central server?			
Please provide an electronic copy of the patch management application configuration file(s). If your software does not have a configuration export utility, provide screenshots of the configuration dialogs.				
5.7	If the patch management software is hosted as an application on a server, is the patch management server properly secured (NTFS or equivalent partition, restricted management console access, passworded console, etc.) Additional information:	☐	☐	☐
Please provide a list of the file and folder permissions for the server on which the patch management software resides. Somarsoft "DumpSec" "Dump Permissions for File system" may be used to easily obtain this list. If you do not have DumpSec, you may download it from: www.somarsoft.com or the auditor will give you a copy upon request.				

Number	Question	Yes	No	N/A
5.8	Is there an up-to-date inventory of hardware and software maintained that includes operating systems and applications installed on each machine, patches applied and patches available but not installed? **If you answer "Yes" to this question, please provide an electronic copy of the patch inventory to the auditors when you return this questionnaire.** Additional information:	☐	☐	☐
5.9	Is there a procedure to track patches that have not been applied to specific systems and the rationale for not having applied the patch? Additional information:	☐	☐	☐
5.11	Is there a procedure for re-inventorying patches to ensure they have not been overwritten? Additional information:	☐	☐	☐

6. Patch Management Maintenance

Number	Question	Yes	No	N/A
6.1	Have patch sources been identified and authorized for download? Additional information:	☐	☐	☐
6.2	Is the credit union subscribed to vendor patch alert email lists? Additional information:	☐	☐	☐
6.2.1	Which ones? Additional information:			
6.3	Does the credit union research or review vendor web sites, third party security vendor web sites or other sites for patch information? Additional information:	☐	☐	☐
6.3.1	Which ones? Additional information:			

7. Consolidated Request List

Number	Requested Item	Provided	Not Provided	Reason not provided
7.1	Electronic copy of any/all patch management policies, procedures or programs in effect	☐	☐	
7.2	Electronic copy of the patch management software configuration file. (If the software does not support exporting configurations, please provide screenshots of the configuration dialogs)	☐	☐	
7.3	DumpSec "Dump Permissions for File system" report for the server(s) on which the patch management software resides	☐	☐	
7.4	Up-to-date inventory of hardware and software maintained that includes operating systems and applications installed on each machine, patches applied and patches available but not installed	☐	☐	

8. Additional Information for the Auditor on Patch Management Controls